

Homelab Hardening Session

Frank Santos — mystikal.dev | June 25, 2026

Session Summary

Task	Status
Vaultwarden config audit (Argon2id token, signups disabled)	■ Done
Vaultwarden port binding locked to 127.0.0.1:8080	■ Done
Vaultwarden TOTP enrolled and verified	■ Done
Proxmox non-root admin user (frank@pve) created	■ Done
Proxmox Administrator role assigned	■ Done
Proxmox TOTP enrolled on frank@pve and root@pam	■ Done
Cloudflare API token rotated	■ Done
Token moved from plaintext Caddyfile to env variable	■ Done
UniFi reverse proxy fixed (WebSocket + CORS)	■ Done

1. Vaultwarden Hardening (LXC 102)

1.1 Config Audit

Verified `/opt/vaultwarden/.env` contained the correct security settings:

```
WEBSOCKET_ENABLED=true
SIGNUPS_ALLOWED=false
ADMIN_TOKEN=$$argon2id$$... (hashed)
```

- `SIGNUPS_ALLOWED=false` prevents unauthorized self-registration
- `ADMIN_TOKEN` uses Argon2id hashing (OWASP preset) — not plaintext

1.2 Port Binding Fix

Vaultwarden was binding to `0.0.0.0:8080` — exposing it to all interfaces on the Servers VLAN. Fixed to bind only to localhost so only Caddy can reach it:

```
Before: - "8080:80"
After:  - "127.0.0.1:8080:80"
```

Command used:

```
sed -i 's/- "8080:80"/- "127.0.0.1:8080:80"/' /opt/vaultwarden/docker-compose.yml
cd /opt/vaultwarden && docker compose down && docker compose up -d
Verified with: docker ps --format "table {{.Names}}\t{{.Status}}\t{{.Ports}}"
```

Result: `127.0.0.1:8080->80/tcp` ■

1.3 TOTP 2FA Enrollment

Enrolled TOTP via vault.mystikal.dev → Account Settings → Security → Two-step Login → Authenticator App.
Recovery code saved as a secure note in Vaultwarden itself.

2. Proxmox Hardening

2.1 Non-Root Admin User

Created a dedicated admin user to replace daily root usage. Root is now break-glass only.

```
pveum user add frank@pve --comment "Frank Admin"
pveum passwd frank@pve
pveum aclmod / -user frank@pve -role Administrator
```

Key note: Realm selection matters. At the Proxmox login screen, use username 'frank' (not frank@pve) and select 'Proxmox VE authentication server' from the realm dropdown — not PAM.

2.2 TOTP Enrollment

TOTP enrolled on both frank@pve and root@pam via the Proxmox web UI: top-right user icon → TFA → Add TOTP.
Verified login challenge works on frank@pve.

3. Cloudflare API Token Security

3.1 Problem

The Cloudflare API token was stored in plaintext in /etc/caddy/Caddyfile, repeated in every TLS block. Anyone with read access to the file (or the chat where it was pasted) could modify DNS records for mystikal.dev — enabling subdomain hijacking, traffic interception, and fraudulent SSL certificate issuance.

3.2 Fix

Step 1 — Rotate the token in Cloudflare dashboard (My Profile → API Tokens → Roll).

Step 2 — Store the new token in a protected env file:

```
echo 'CLOUDFLARE_API_TOKEN=' > /etc/caddy/caddy.env
chown caddy:caddy /etc/caddy/caddy.env && chmod 600 /etc/caddy/caddy.env
```

Step 3 — Create systemd override to load the env file:

```
mkdir -p /etc/systemd/system/caddy.service.d/
cat > /etc/systemd/system/caddy.service.d/override.conf << 'EOF' [Service]
EnvironmentFile=/etc/caddy/caddy.env EOF
```

Step 4 — Replace plaintext token in Caddyfile with variable reference:

```
dns cloudflare {env.CLOUDFLARE_API_TOKEN}

systemctl daemon-reload && systemctl restart caddy
```

4. UniFi Reverse Proxy Fix

4.1 Symptoms

unifi.mystikal.dev would load the login page and MFA prompt, but hang indefinitely after MFA completed. Direct IP access (https://192.168.1.69:11443) worked fine.

4.2 Root Cause

UniFi OS runs inside a podman container with its own nginx. After MFA, the UI attempts WebSocket connections to wss://unifi.mystikal.dev/api/ws/system and /api/ws/webrtc/local.

UniFi's nginx validates the WebSocket Origin header against an internal CORS allowlist. Since mystikal.dev was not in the allowlist, nginx returned HTTP 500 on every WebSocket handshake, preventing the UI from loading.

4.3 Fix

Added two nginx map include files inside the UniFi OS podman container:

```
/data/unifi-core/config/http/cors-origin-mystikal.conf
~^https://unifi\.mystikal\.dev$ $http_origin;

/data/unifi-core/config/http/cors-credentials-mystikal.conf
~^https://unifi\.mystikal\.dev$ "true";

nginx -s reload # inside the container
```

These files are in the /data volume which maps to a persistent podman volume on the host (/home/uosserver/.local/share/containers/storage/volumes/uosserver_data/_data). Changes survive container updates.

4.4 Final Caddyfile (UniFi block)

```
unifi.mystikal.dev { reverse_proxy https://192.168.1.69:11443 { transport http {
  tls_insecure_skip_verify versions 1.1 } header_up Host {upstream_hostport} header_up X-Real-IP
{remote_host} header_up X-Forwarded-For {remote_host} header_up X-Forwarded-Proto {scheme} }
header { -X-Frame-Options } tls { dns cloudflare {env.CLOUDFLARE_API_TOKEN} } }
```

5. Next Steps

- Migrate Caddy to its own dedicated LXC (currently co-located on Vaultwarden LXC 102)
- Deploy Wazuh SIEM — ingest OPNsense, Proxmox, and LXC logs
- Deploy Home Assistant on IoT VLAN with proper isolation
- Set up Authentik or Keycloak for SSO across all services
- Terraform/Ansible for LXC provisioning (infrastructure-as-code)
- Grafana + Prometheus observability stack
- Document everything in MkDocs Material site (HomeLab-Docs repo)